NEXUS SECURITY ADVISORS

# AI Agent Onboarding & Offboarding Checklist

**Organizations running AI agents, copilots, and automations with access to business systems**

Treat every AI agent as a non-human identity: inventory it, onboard it with least privilege, review it with user access, and retire it completely when the pilot ends or its owner leaves. Mapped to NIST SP 800-53 account management, the NIST AI RMF, ISO/IEC 42001, and the OWASP Top 10 for LLM Applications 2025.

Organization: _____ Completed by: _____ Date: _____

| ☐ | ID | Section | Requirement | Reference | Priority | Evidence |
|---|---|---|---|---|---|---|
| ☐ | AGENT-01 | Inventory | Maintain a register of every AI agent and automation, including those built in AI platforms, low-code, and workflow tools | NIST AI RMF GOVERN 1.6; NIST SP 800-53 AC-2 | High | Agent register |
| ☐ | AGENT-02 | Inventory | Review OAuth app consents and API key lists in core SaaS for grants held by agents | NIST SP 800-53 AC-2; CIS Controls v8 5.1 | High | OAuth and API key review export |
| ☐ | AGENT-03 | Inventory | Record each agent's owner, purpose, credentials, connected systems, triggers, and data stores | NIST AI RMF MAP; ISO/IEC 42001 | High | Completed register fields |
| ☐ | AGENT-04 | Onboarding | Document business purpose, risk tier, and expected end date before an agent goes live | NIST AI RMF MAP; ISO/IEC 42001 | Medium | Approval record |
| ☐ | AGENT-05 | Onboarding | Assign a named human owner and a backup owner to every agent | NIST AI RMF GOVERN; NIST SP 800-53 AC-2 | High | Register owner fields |
| ☐ | AGENT-06 | Onboarding | Give each agent its own non-human identity, never a shared account or a person's login | NIST SP 800-53 AC-2, IA-9 | High | Service account list |
| ☐ | AGENT-07 | Onboarding | Grant least-privilege scopes: read-only unless writing is required, limited to specific folders, tables, or channels | NIST SP 800-53 AC-6; OWASP LLM06:2025 Excessive Agency | High | Scope review |
| ☐ | AGENT-08 | Onboarding | Keep secrets in a secrets manager and set an expiry date on every key and token | NIST SP 800-53 IA-5 | High | Secrets inventory with expiry dates |
| ☐ | AGENT-09 | Onboarding | List every trigger (schedules, webhooks, events, other agents) and require signed or authenticated webhooks | OWASP LLM06:2025 Excessive Agency | High | Trigger list; webhook configuration |
| ☐ | AGENT-10 | Onboarding | Require human approval for high-impact actions such as payments, deletions, external email, and permission changes | OWASP LLM06:2025; NIST AI RMF MANAGE | High | Approval workflow configuration |

| ☐ | ID | Section | Requirement | Reference | Priority | Evidence |
|---|---|---|---|---|---|---|
| ☐ | AGENT-11 | Onboarding | Define the data each agent can read and store, and set retention for memory, vector stores, and logs | NIST AI RMF MAP; ISO/IEC 42001 | Medium | Data scope; retention settings |
| ☐ | AGENT-12 | Onboarding | Log agent actions under the agent's own identity and test the kill switch before launch | NIST SP 800-53 AU-2; NIST AI RMF MANAGE | High | Log sample; kill-switch test record |
| ☐ | AGENT-13 | Onboarding | Test guardrails before launch with prompt injection and planted fake secrets | OWASP LLM01:2025 Prompt Injection; NIST AI RMF MEASURE | Medium | Test results |
| ☐ | AGENT-14 | Ongoing review | Include agents in user access reviews on the same cadence (quarterly; monthly for high-risk agents) | NIST SP 800-53 AC-2 | High | Access review record |
| ☐ | AGENT-15 | Ongoing review | Flag agents with no run in 30 days and start offboarding at 60 days unless the owner justifies keeping them | NIST SP 800-53 AC-2(3) | Medium | Dormancy report |
| ☐ | AGENT-16 | Ongoing review | Remove unused scopes and rotate credentials on schedule | NIST SP 800-53 AC-6, IA-5 | Medium | Rotation log |
| ☐ | AGENT-17 | Ongoing review | When a person leaves, review every agent they own or that runs on their OAuth grant | NIST SP 800-53 PS-4 | High | Offboarding ticket |
| ☐ | AGENT-18 | Offboarding | Disable every trigger first so a dormant agent can't be woken during cleanup | OWASP LLM06:2025 Excessive Agency | High | Trigger removal record |
| ☐ | AGENT-19 | Offboarding | Revoke keys, tokens, and OAuth grants, then disable the agent's identity and integrations | NIST SP 800-53 AC-2, PS-4 | High | Revocation record |
| ☐ | AGENT-20 | Offboarding | Confirm no production workflow or other agent depends on it, and notify its users | NIST AI RMF MANAGE | Medium | Dependency check |
| ☐ | AGENT-21 | Offboarding | Decide keep, archive, or delete for memory, vector stores, prompts, and files; retain audit logs | ISO/IEC 42001; NIST SP 800-53 AU-11 | Medium | Data disposition record |
| ☐ | AGENT-22 | Offboarding | Verify the agent can't run and its credentials fail, then close the register entry with owner and security sign-off | NIST AI RMF GOVERN 1.7 | High | Closure sign-off |

Readiness self-check for general guidance only. Not legal advice and not a formal assessment or certification. Confirm requirements against official sources.